

New MySafe - Account Recovery

senhasegura

Departamento de Segurança e Inovação - SEGi9



CONFIDENCIAL



Resumo Executivo

Este texto aborda o processo de recuperação das chaves de criptografia dos Usuários, no qual o Custodiante designado restaura as chaves de criptografia dos usuários de uma organização. Desta forma, o Custodiante restabelece o acesso em casos de esquecimento ou perda da senha mestra por parte dos Usuários. Essa funcionalidade pode ser ativada para a organização ao habilitar a política de administração de recuperação de chave de criptografia.





Sumário

1	Segurança das Chaves de Criptografia	1
1.1	Alice	1
1.2	Bob	2
2	Custódia das Chaves de Criptografia	5
2.1	Custodiando	5
3	Recuperando Custódia das Chaves	7
3.1	Gerando Nova Chave Mestra - Bob	7
3.2	Nova Custódia - Alice	8





1 Segurança das Chaves de Criptografia

1.1 Alice

Processo de criação das chaves, Pública (KPUAlice.pem), Privada (KPrAlice.pem) e de Dados (DEKAlice.bin), juntamente com o processo de encriptação para armazenamento seguro das chaves Privada (KPrAlice.pem) e de Dados (DEKAlice).

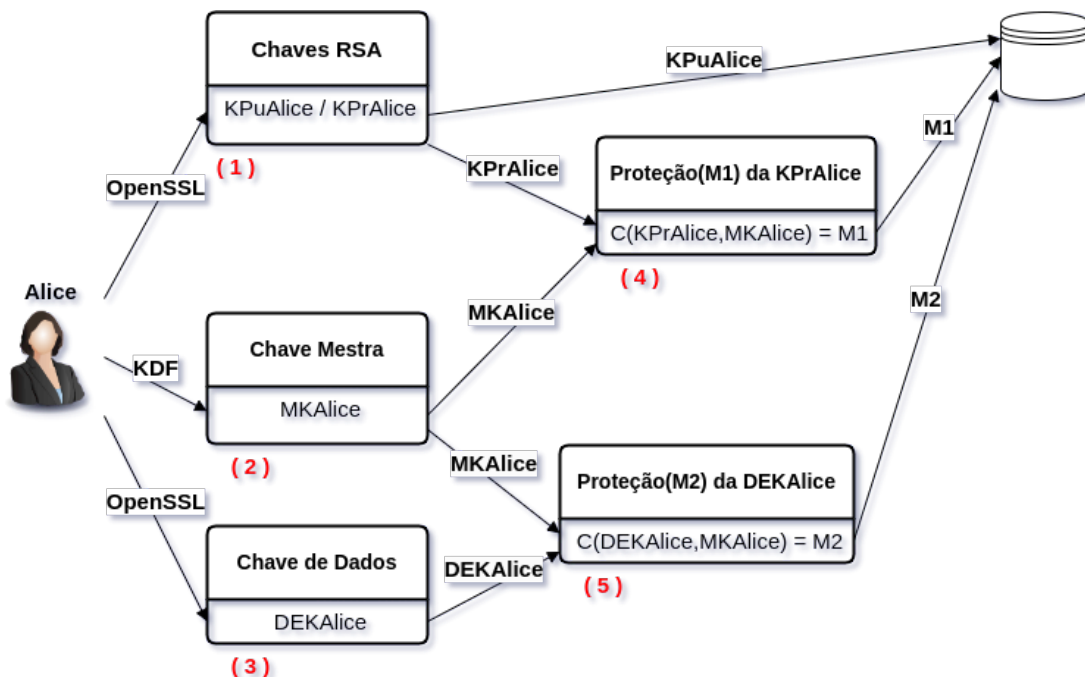


Figura 1: Chaves e Processos associadas a Alice

1. Criação da Chave Pública (KPUAlice.pem) e da Chave Privada (KPrAlice.pem);

```
$ openssl genpkey -algorithm RSA -out KPrAlice.pem  
$ openssl rsa -pubout -in KPrAlice.pem -out KPUAlice.pem
```

2. Criação da Chave Mestra (MKAlice.txt) que é baseada na derivação da Senha Mestra (MPAlice);





```
$ MASTER_PASSWORD="MPALice"  
  
$ SALT=$(openssl rand -hex 8) # Gera uma salt de 8 bytes (16 caracteres hexadecimais)  
  
$ openssl enc -aes-256-cbc -pbkdf2 -k "$MASTER_PASSWORD" -S "$SALT" -iter 10000 -P > MKALice.txt
```

3. Criação da Chave de Dados (DEKAlice.bin);

```
$ openssl rand -out DEKAlice.bin 32
```

4. A Chave Privada (KPrAlice.pem) é protegida com a Chave Mestra (MKALice.txt) gerando o Texto Cifrado M1 que é enviado para o servidor;

```
$ openssl enc -aes-256-cbc -in KPrAlice.pem -out M1.bin -pass file:./MKALice.txt -pbkdf2
```

5. A Chave de Dados (DEKAlice.bin) é protegida com a Chave Mestra (MKALice.txt) gerando o Texto Cifrado M2 que é enviado para o servidor.

```
$ openssl enc -aes-256-cbc -in DEKAlice.bin -out M2.bin -pass file:./MKALice.txt -pbkdf2
```

1.2 Bob

Processo de criação das chaves, Pública (KPuBob.pem), Privada (KPrBob.pem) e de Dados (DEKBob.bin), juntamente com o processo de encriptação para armazenamento seguro das chaves Privada (KPrBob.pem) e de Dados (DEKBob.bin).



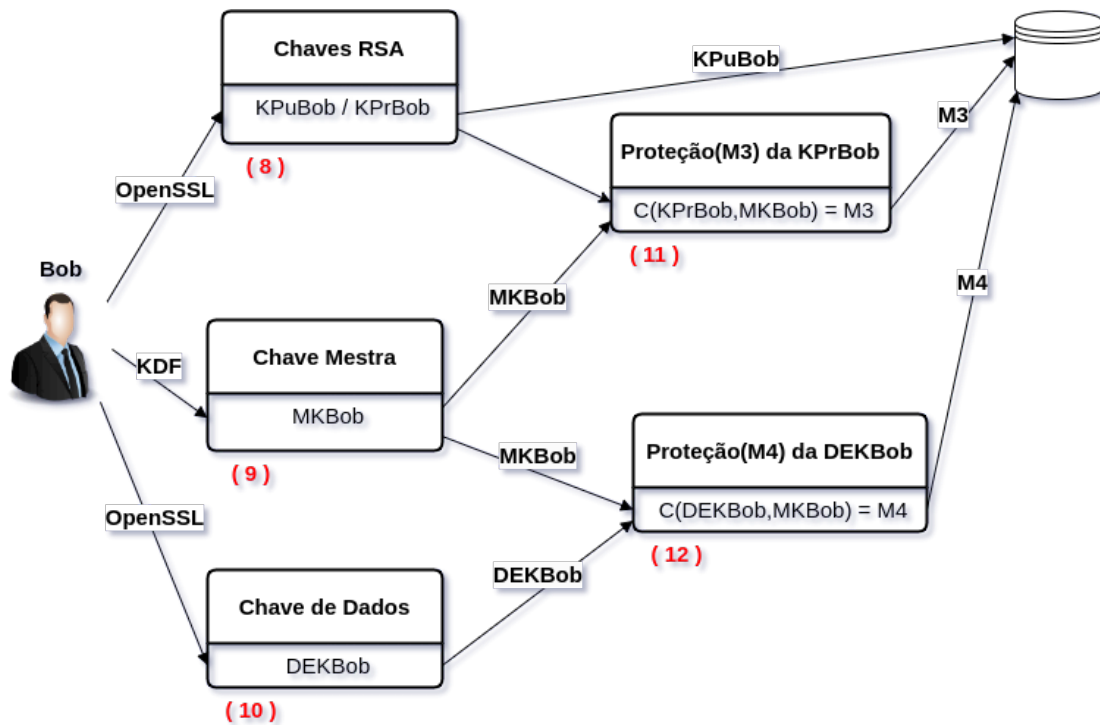


Figura 2: Chaves e Processos associados ao Bob

8. Criação das Chave Pública (KPubBob.pem) e da Chave Privada (KPrBob.pem);

```
$ openssl genpkey -algorithm RSA -out KPrBob.pem  
$ openssl rsa -pubout -in KPrBob.pem -out KPubBob.pem
```

9. Criação da Chave Mestra (MKBob.txt) baseada na derivação da Senha Mestra (MPBob);

```
$ MASTER_PASSWORD="MPBob"  
  
$ SALT=$(openssl rand -hex 8) # Gera uma salt de 8 bytes (16 caracteres hexadecimais)  
  
$ openssl enc -aes-256-cbc -pbkdf2 -k "$MASTER_PASSWORD" -S "$SALT" -iter 10000 -P > MPBob.txt
```

10. Criação da Chave de Dados (DEKBob.bin);





```
$ openssl rand -out DEKBob.bin 32
```

11. A Chave Privada (KPrBob) é protegida com a Chave Mestra (MKBob.txt) gerando o Texto Cifrado M3 que é enviado para o servidor;

```
$ openssl enc -aes-256-cbc -in KPrBob.pem -out M3.bin -pass file:./MKBob.txt -pbkdf2
```

12. A Chave de Dados (DEKBob.bin) é protegida com a Chave Mestra (MKBob.txt) gerando o Texto Cifrado M4 que é enviado para o servidor.

```
$ openssl enc -aes-256-cbc -in DEKBob.bin -out M4.bin -pass file:./MKBob.txt -pbkdf2
```





2 Custódia das Chaves de Criptografia

No exemplo apresentado, Alice é a usuária Custodiante e Bob é o usuário que terá as suas chaves custodiadas. Assim, todas as chaves do Bob devem ser compartilhadas com a Custodiante Alice.

2.1 Custodiando

Bob irá custodiar as suas duas chaves, Chave Privada(KPrBob.pem) e Chave de Dados(DEKBob.bin), com a custodiante Alice.

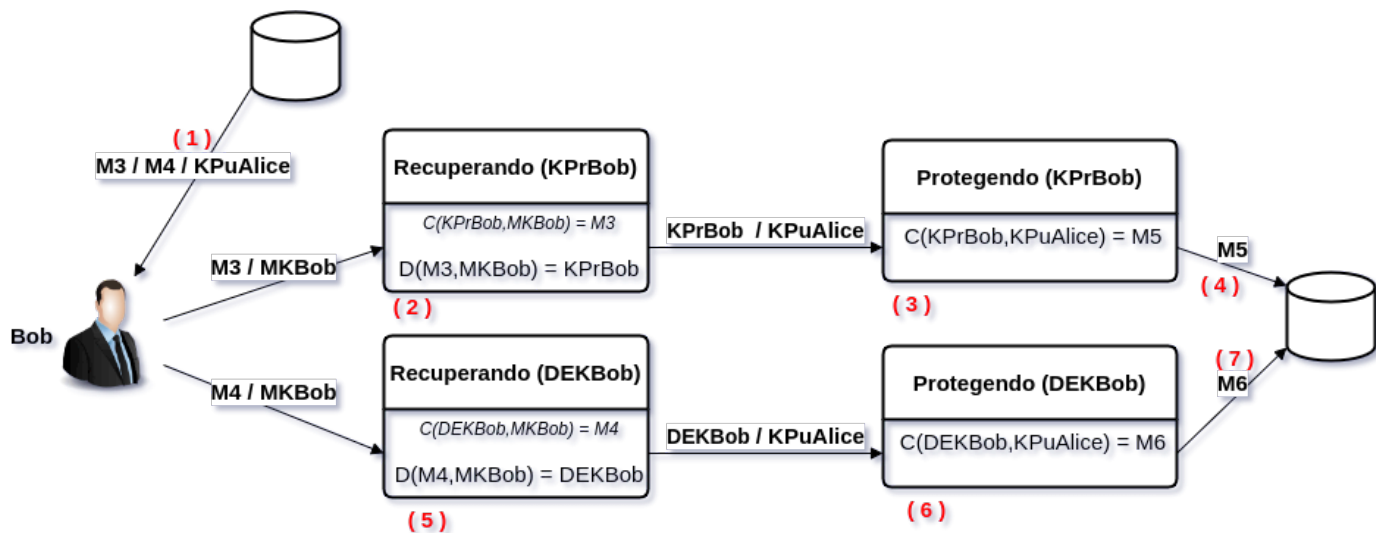


Figura 3: Processos de Custódia das Chaves do Bob

1. Bob recupera os Textos Cifrados M3 e M4 e a Chave Pública da Alice(KpuAlice) do servidor;
2. Bob descriptografa o Texto Cifrado M3 com a sua Chave Mestra (MK-Bob.txt) para obter a sua Chave Privada (KPrBob);

```
$ openssl enc -d -aes-256-cbc -in M3.bin -out KPrBob.pem -pass file:./MKBob.txt -pbkdf2
```

3. Bob criptografa a sua Chave Privada(KPrBob.pem) com a sua Chave de Dados (DEKBob.bin) gerando o Texto Cifrado M5.





```
$ openssl enc -aes-256-cbc -in KPrBob.pem -out M5.bin -pass file:./DEKBob.bin -pbkdf2
```

4. Bob envia o Texto Cifrado M5 para o Servidor;
5. Bob descriptografa o Texto Cifrado M4 com a sua Chave Mestra (MK-Bob.txt) para obter a sua Chave de Dados (DEKBob.bin);

```
$ openssl enc -d -aes-256-cbc -in M4.bin -out DEKBob.bin -pass file:./MKBob.txt -pbkdf2
```

6. Bob criptografa sua Chave de Dados (DEKBob.bin) com a Chave Pública da Alice (KPUAlice.pem), gerando o Texto Cifrado M6.bin;

```
$ openssl pkeyutl -encrypt -inkey KPUAlice.pem -pubin -in DEKBob.bin -out M6.bin
```

7. Bob envia o Texto Cifrado M6 para o Servidor;





3 Recuperando Custódia das Chaves

Em um cenário em que Bob perde sua Chave Mestra (MKBob.txt), ele solicita à custodiante Alice que criptografe suas duas chaves, Chave Privada (KPr-Bob.pem) e Chave de Dados (DEKBob.bin), com a Nova Chave Mestra (NMKBob.txt).

3.1 Gerando Nova Chave Mestra - Bob

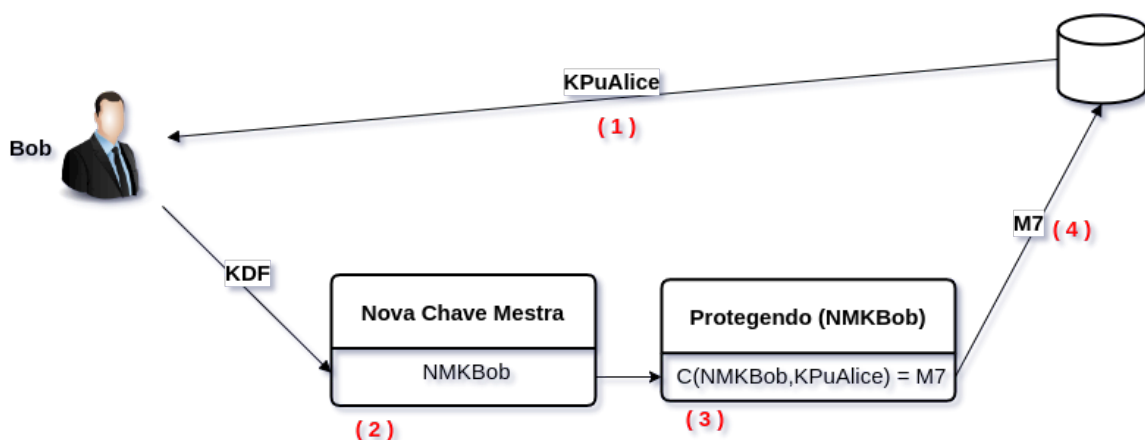


Figura 4: Processos de criação da Nova Chave Mestra do Bob

1. Bob recupera a Chave Pública da Alice (KPUAlice.pem) que está armazenada no servidor;
2. Utilizando a tecnologia Key Derivation Function (KDF), Bob irá gerar uma Nova Chave Mestra (NMKBob.txt);

```
$ MASTER_PASSWORD="NMPBob"
$ SALT=$(openssl rand -hex 8)
$ openssl enc -aes-256-cbc -pbkdf2 -k "$MASTER_PASSWORD" -S "$SALT" -iter 10000 -P > NMPBob.txt
```

3. Utilizando a Chave Pública da Alice (KPUAlice.pem), Bob irá criptografar a sua Nova Chave Mestra (NMKBob.txt) gerando o Texto Criptografado M8;





```
$ openssl pkeyutl -encrypt -inkey KPuAlice.pem -pubin -in NMKBob.txt -out M8.bin
```

4. O Texto Criptografado M8 será enviado para o servidor.

3.2 Nova Custódia - Alice

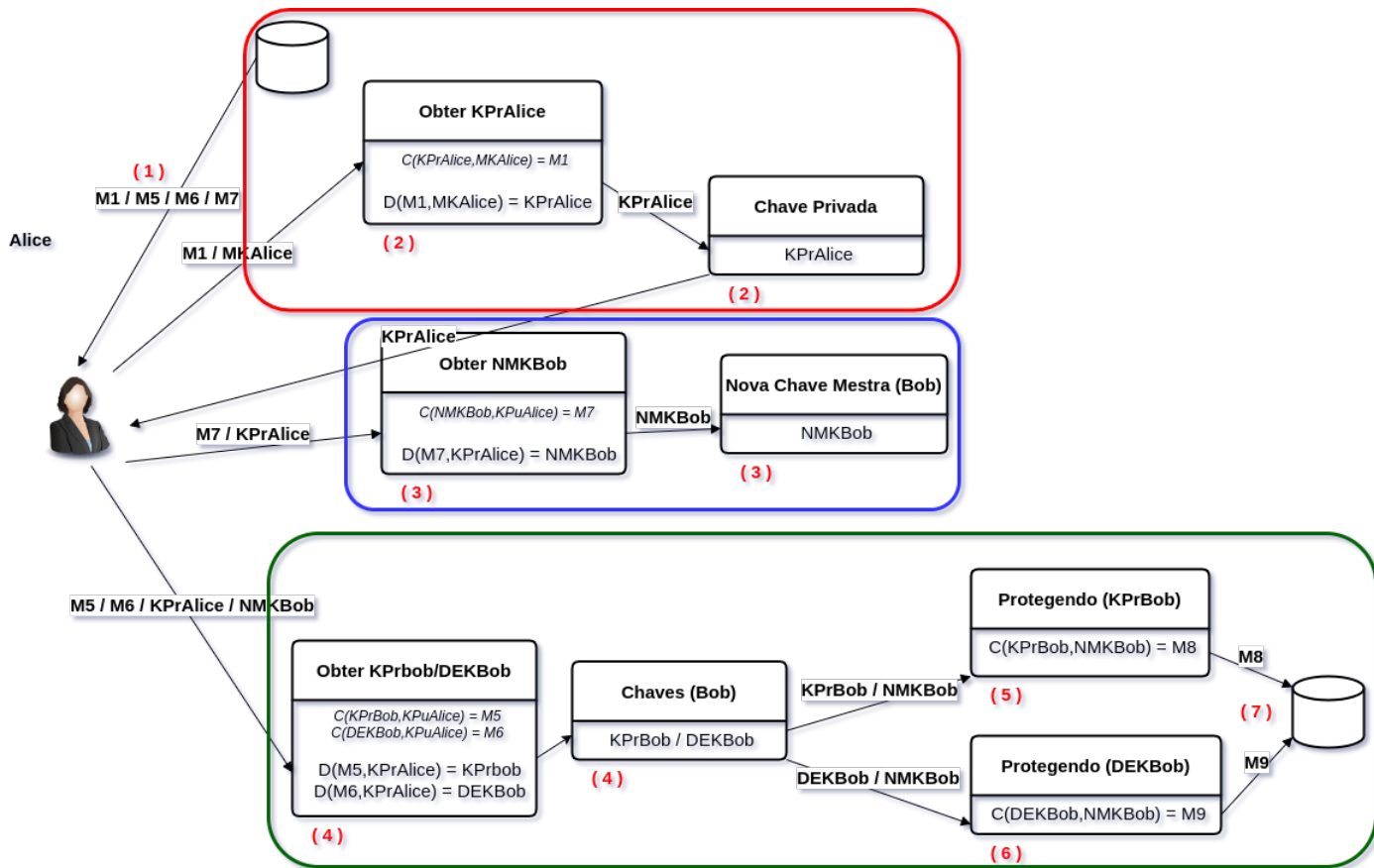


Figura 5: Processos de proteção das chaves do Bob com a sua Nova Chave Mestra

1. Alice faz o download dos Textos Cifrados M1, M5, M6 e M7 do servidor;
2. Alice descriptografa o Texto Cifrado M1 com a sua Chave Mestra (MKAlice.txt) para obter a sua Chave Privada (KPrAlice.pem);





```
$ openssl enc -d -aes-256-cbc -in M1.bin -out KPrAlice.pem -pass file:./MKAlice.txt -pbkdf2
```

3. Com a sua Chave Privada (KPrAlice.pem), Alice descriptografa o Texto Cifrado M8 e obtém a Nova Chave Mestra (NMKBob.txt) do Bob;

```
$ openssl pkeyutl -decrypt -inkey KPrAlice.pem -in M8.bin -out NMKBob.txt
```

4. Com a sua Chave Privada (KPrAlice.txt), Alice descriptografa os Textos Cifrados M3 e M4 e obtém a Chaves Privada do Bob (KPrBob.txt) e a Chave Dados do Bob (DEKBob.txt);

```
$ openssl pkeyutl -decrypt -inkey KPrAlice.pem -in M3.bin -out KPrBob.pem  
$ openssl pkeyutl -decrypt -inkey KPrAlice.pem -in M4.bin -out DEKBob.bin
```

5. Com a Nova Chave Mestra do Bob (NMKBob), Alice criptografa a Chave Privada do Bob (KPrBob.pem) gerando o Texto Cifrado M8;

```
$ openssl enc -aes-256-cbc -in KPrBob.pem -out M8.bin -pass file:./NMKBob.bin
```

6. Com a Nova Chave Mestra do Bob(NMKBob), Alice criptografa a Chave de Dados do Bob (DEKBob.bin) gerando o Texto Cifrado M9;

```
$ openssl enc -aes-256-cbc -in DEKBob.bin -out M9.bin -pass file:./NMKBob.bin
```

7. Os Textos Cifrados M8 e M9 são enviados para o servidor.

A partir deste ponto, a Chave Privada do Bob (KPrBob.bin) e a Chave de Dados do Bob (DEKBob.bin) estão protegidas com a Nova Chave Mestra do Bob (NMKBob.bin) e estão armazenadas no servidor.





Copyright

All rights reserved to MT4 Tecnologia LTDA.

Propósito deste documento

New MySafe - Account Recovery

Versão

Versão 1.0

Autor

Caio Abreu Ferreira [cferreiras@senhasegura.com]

MT4 Tecnologia Ltda.

Rua Joaquim Antunes, 767 – Pinheiros – São Paulo

Phone: +55 11 3065-7070

www.mt4.com.br

